

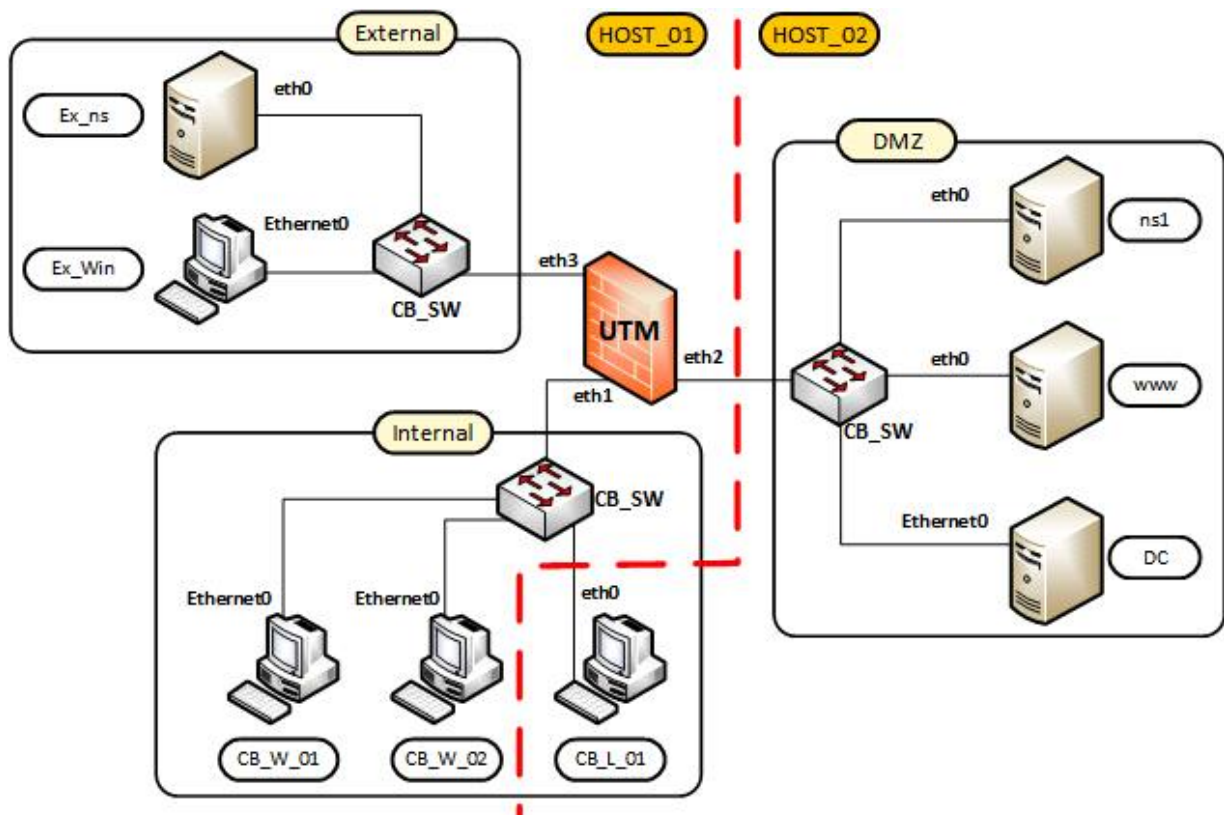
# 2019년 지방기능경기대회 과제

|       |        |     |            |            |       |
|-------|--------|-----|------------|------------|-------|
| 직 종 명 | 사이버 보안 | 과제명 | 보안 구성 및 분석 | 과제번호       | 제 2과제 |
| 경기시간  | 5시간    | 비번호 |            | 감독위원<br>확인 | (인)   |

## 1. 과제 소개

### 가. 과제의 개요

당신은 ㈜경기닷컴의 보안팀에서 근무하게 된 신입 보안 엔지니어입니다. 당신이 시뮬레이션을 위해 구축한 토폴로지에 내/외부의 보안 위협을 위한 추가 설정 및 시스템 및 네트워크, 어플리케이션 보안 취약점을 탐지하고 추후 발생할 수 있는 보안 위협에 대응 할 정책들을 마련해야 합니다.



## 나. 사전 준비

### 1) 운영체제 및 소프트웨어

- Wireshark 64bit 최신버전
- Microsoft Office 2016
- kali-linux-2019.1-amd64
- TestSRV vmware 이미지

### 2) 과제 수행시 유의사항

작업시 대소문자를 구별하여 과제를 수행해야 합니다.

가) 채점 시 서비스 및 운영체제 재시작은 총 2회만 가능합니다.

나) 특별히 지정된 암호 이외의 모든 "cyberP@ss12#\$"으로 설정합니다.

다) 시스템을 재부팅 시에도 각 서버의 서비스들이 원활히 동작해야 합니다.

라) 대회장에서 제공되지 않은 소프트웨어 설치하는 부정행위로 간주됩니다.

마) 선수는 모든 전자기기 및 저장장치 휴대를 금합니다.

바) 서버 및 클라이언트 방화벽 정책을 임의로 수정하면 감점 또는 "0"점 처리될 수 있습니다.

### 3) 해킹서버 설치 : HOST-01 에 추가 설치한다. CB-W-01 과 같은 네트워크를 사용한다.

- 해킹서버의 IP는 DC서버에서 dhcp 통해 구성합니다.

이미지 : kali-linux-2019.1-amd64.iso

|        |                           |
|--------|---------------------------|
| 호스트 이름 | attacker (D:WVMWattacker) |
| RAM    | 1GB                       |
| 파티션    | 기본 설정                     |
| 암호     | cyberP@ss12#\$            |
| 기타     | Graphical Install         |

### 4) TestSRV 이미지는 DMZ 네트워크에 연결한다.

### 5) 부록 : 1과제 설치 정보

## 2. 과제내용

### 가. 리눅스 시스템보안

- 모든 리눅스 운영체제에 적용한다.

#### 1) 실행된 명령어 관리

- 가) 리눅스에 로그인 가능한 모든 사용자가 실행시켰던 명령어가 다음과 같이 “년-월-일\_시:분:초”를 포함하도록 설정합니다.

```
2019-03-25_09:58:10 ls -al
```

- 나) 사용자별로 실행됐던 명령어는 최근 20개 까지만 저장되도록 한다.

- 다) root 는 리눅스 시스템에서 명령어의 기록을 다음과 같이 로그로 남기도록 설정하시오. 로그는 /var/log/cmd.log 로 저장하며, root 사용자만 확인할 수 있어야 한다.

```
Feb 25 19:21:17 ns1 kgAdmin: [2] STAT=0
Feb 25 19:21:17 ns1 kgAdmin: [1] PID=7432, PWD=/home/kgAdmin, TTY=/dev/pts/0, CMD= 24 2019-02-25_
09:53:26history
```

#### 2) 세션관리

사용자의 1분 동안 아무런 작업을 하지 않으면 로그아웃되도록 설정하시오.

#### 3) root 사용자 보안

root 사용자는 터미널/원격 등 모든 경로에서 직접 로그인이 불가능하도록 설정하시오.

#### 4) 계정 보안

1. 패스워드는 반드시 영문, 숫자, 특수문자를 포함하여 최소 8자리 이상을 만족해야 합니다.
2. 패스워드는 마지막 변경일로부터 최소 1일간 사용되어야 하며, 90일 마다 변경 되도록 합니다. 또한 만료 30일전에는 경고메시지가 출력되어야 합니다.
3. 암호 변경 시 이전 암호를 5개까지 기억하여, 사용했던 암호의 재사용을 방지합니다.
3. 모든 사용자(root 포함)는 로그인 3회 실패 시 해당 계정이 잠기도록 하며, 이는 관리자가 직접 잠금 해제 시켜야 다시 로그인이 가능합니다.
4. su 명령어의 사용을 secu2019, kgAdmin 계정만 가능하도록 하며, su 사용 시 /var/log/su.log에 로그가 남도록 합니다.

## 나. 윈도우 서버 보안, 그룹정책

- 1) Administrator 의 이름을 kgAdmin2019 으로 변경하고, Guest 계정은 사용하지 않도록 설정한다.
- 2) AD에 가입된 모든 윈도우 OS 들은 하드디스크가 기본 공유되지 않도록 한다.

- 3) RDP 연결 포트를 2019로 변경하며, 기존과 동일한 서비스를 유지해야 한다.

### 4) 계정 암호 정책

1. 암호는 복잡성을 만족
2. 암호는 최소 1일간 사용되어야 하며, 30일 마다 변경되도록 합니다.
3. 암호는 해독이 불가능 하도록 저장되어야 한다.
4. 사용자 암호 변경 시 최근 암호를 24개까지 기억하여, 유사 암호로 재변경하는 일이 없도록 합니다.

### 5) 계정 잠금 정책

- 모든 사용자는 로그인 3회 실패 시 1시간 동안만 계정이 잠기도록 한다.

### 6) 도메인 사용자 정책

1. 모든 사용자들의 “문서” 폴더를 WWDCUsers 폴더로 리디렉션 하도록 설정합니다.
  - 절대 위치는 DC서버의 c:\WkgWuser 이며, 파일 및 저장소 서비스를 통해 공유를 설정해야 합니다.
  - Web, Sys, Secu OU의 사용자들은 모든 권한을 갖습니다.
2. 사용자가 서버에 로그인 및 로그아웃 시 로그가 기록되도록 합니다.
  - 로그인 로그 : Login, 날짜, 시간, 사용자명, 접속서버이름
  - 로그아웃 로그 : Logout, 날짜, 시간, 사용자명, 접속서버이름
  - 저장 : c:\Users\Log\사용자명.log

remote 사용자가 dc 서버에 원격으로 접속했다면 remote.log 에 다음과 같은 로그가 남는다.

```
Login,2019-04-03,14:21:18.06,remote,DC
Logout,2019-04-03,14:24:01.76,remote,DC
```

## 다. 어플리케이션보안

### 1) 터미널 보안

DMZ의 리눅스 운영체제에 SSH 접속 시 인증키를 이용하여 자동으로 접속되도록 합니다. puttygen으로 생성된 개인키를 이용하여 서버에 자동으로 접속되도록 합니다.

가) 인증키 생성서버 : ns1, www 서버

나) Identification 위치 : 바탕화면W비번호\_서버명\_id\_rsa

- 예) 비번호가 101 이라면 101\_ns1\_id\_rsa, 101\_www\_id\_rsa

다) private key 위치 : 바탕화면W선수번호-ns1.ppk, 선수번호-www.ppk

라) ssh 접속 계정 : kgAdmin

- putty를 통해 ssh 접속을 위해 자동 접속을 위해 세션정보를 저장해둔다.

- putty에 저장할 세션 이름 ns1-ssh, www-ssh

- ns1-ssh를 실행하면 ns1 서버에 자동으로 인증되어야 하고, www-ssh를 실행하면 www 서버에 자동으로 인증되어야 한다.

마) CB-W-02 컴퓨터의 secu001 계정에서 사용가능도록 설정한다.

### 2) 웹 서비스

http://www.kg.com 웹 페이지 접속 시 web001 ~ web005 계정을 통해 basic 인증을 받도록 구성합니다. 또한, 웹 페이지 접근 시 /var/log/httpd/kg.com/access.log 에 다음과 같은 형식으로 로그가 남도록 설정합니다.

|                                                               |
|---------------------------------------------------------------|
| 접근시간 : 접근IP : 인증사용자 : “UR L” : 클라이언트 요청 정보 : “브라우저 정보” : 상태코드 |
|---------------------------------------------------------------|

3) 그 외 보안 설정은 다음에서 제시되는 취약점 분석에 따릅니다.

## 라. 네트워크보안

### 1) 스위치 보안

가) 스위치의 콘솔 및 ssh 접속을 위해 AAA 설정을 합니다. 인증 www 서버에서 라디우스 인증이 되도록 합니다.

나) 라디우스 인증 계정은 ciscoAdmin(레벨 15), ciscoUser(레벨1)을 사용하며, 암호는 과제의 기본 암호를 사용합니다.

다) 라디우스 인증 실패 시 CB-SW의 로컬계정으로 로그인되도록 설정합니다.

라) 스위치의 원격 접속은 Security 네트워크에서만 접속 가능해야 합니다.

## 2) UTM 보안

1. 트래픽 기본 흐름 : Internal -> 모든방향, DMZ -> External
2. 허용할 서비스는 과제에 제시된 서비스만 허용합니다. 단, external 을 목적지로 하는 경우는 모든 서비스를 허용합니다
3. 허용할 네트워크는 과제에서 제시된 네트워크만 허용하며, 내부 네트워크 객체이름은 vlan name 과 동일하게 사용하고, External, DMZ은 존이름과 동일하게 사용합니다.
5. 이 외의 필요한 정책은 위의 조건에 영향을 주지 않는 내에서 설정합니다.

### 마. 취약점 분석 및 대응

- attacker 리눅스를 공격자PC로 사용하여 과제를 해결합니다.

1) 192.168.150.0/25 네트워크에 사용 중인 IP를 검색합니다.

가) 사용중인 IP를 검색한 결과를 attacker 바탕화면에 192hosts.txt 로 저장합니다.

2) attacker에서 nmap을 이용하여 TestSRV 리눅스 서버 취약점을 분석하여 제시된 양식을 완성하여 제출하시오. 파일은 다음의 형태를 포함하여 대회장에서 배포됨(제출파일명 : 비번호.docx)

비번호:

1. TestSRV의 IP =

- 위 IP를 찾은 화면을 캡처해 붙여넣으시오.

2. TestSRV에 대해 외부로 드러나 취약점을 찾아 표에 넣으시오.

| OS/프로토콜 | 버전      | 포트 | 취약점 |
|---------|---------|----|-----|
| 예시) OS  | Win x64 | x  |     |
| 예시) ssh | openssh | 22 |     |
|         |         |    |     |
|         |         |    |     |

3. root를 포함하여 발견한 사용자 계정을 모두 나열하시오.

root,

4. 위 2번 표와 관련하여 어떤 문제를 해결하였는지 작성하시오.

4-1.

4-2.

3) attacker에서 해킹 툴을 이용하여 TestSRV의 root 패스워드를 크래킹을 시도합니다. TestSRV 서버에 접속한 후 취약점을 제거해야 합니다.

가) root를 포함한 사용자들의 암호를 cyberP@ss12#\$ 으로 변경합니다.

나) 그 외의 서비스에 불필요한 접속 허용 및 공유 등을 제거합니다. 사용예정인 서비스 ssh, http, ftp

## 부록. 운영체제의 구성 및 설치

Guest OS의 설치 위치는 “D:\VM\컴퓨터이름”폴더로 합니다. 모든 운영체제의 관리자계정(root / administrator)의 암호는 “cyberP@ss12#\$”로 지정합니다. 아래 표에서 제시되지 않은 설정 중 반드시 필요한 설정에 한하여 선수 임의로 지정하되, 불필요한 설정은 채점에서 불이익을 받을 수 있습니다.

### ○ Windows 10 Enterprise

#### - 호스트 컴퓨터

|        |                             |         |
|--------|-----------------------------|---------|
| 컴퓨터 이름 | HOST-01                     | HOST-02 |
| 파티션    | C:W (60GB) , D:W (400GB 이상) |         |
| 추가 사용자 | user                        |         |

#### - 게스트 컴퓨터

|        |         |         |        |
|--------|---------|---------|--------|
| 컴퓨터이름  | CB-W-01 | CB-W-02 | Ex-Win |
| 추가 사용자 | user    |         |        |

### ○ GNU/Linux CentOS

|          |               |      |     |       |
|----------|---------------|------|-----|-------|
| 호스트 이름   | CB-L-01       | ns1  | www | Ex-ns |
| RAM      | 4GB           | 2GB  | 2GB | 2GB   |
| 파티션      | 기본 설정         |      |     |       |
| 사용자(관리자) | secu2019      |      |     |       |
| 기타       | GNOME Desktop | 최소설치 |     |       |

### ○ Windows Server 2019 Standard GUI

|        |        |
|--------|--------|
| 컴퓨터 이름 | DC     |
| 추가 사용자 | remote |

## 4) 네트워크 구성

### 가) 기본 구성

- 위 도면을 참고하여 제공되는 UTP 케이블을 컴퓨터 NIC, 스위치, UTM 간에 상호 연결합니다.
- 게이트웨이 주소는 필요한 경우에 한하여 해당 서브넷에서 사용 가능한 마지막 주소를 사용합니다.

### 나) IP구성

| 구분       | 네트워크                        | 호스트     | IP주소           |
|----------|-----------------------------|---------|----------------|
| Internal | vlan 10<br>172.30.10.0/24   | CB-W-01 | DHCP           |
|          | vlan 20<br>172.30.20.0/24   | CB-W-02 | DHCP           |
|          | vlan 30<br>172.30.30.0/24   | CB-L-01 | 172.30.30.1    |
|          |                             | CB-SW   | 172.30.30.100  |
|          |                             | UTM     | 172.30.30.254  |
| DMZ      | vlan 80<br>192.168.150.0/25 | ns1     | 192.168.150.1  |
|          |                             | www     | 192.168.150.5  |
|          |                             | DC      | 192.168.150.10 |
| External | vlan 100<br>69.123.44.0/27  | Ex-ns   | 사용 가능한 첫 번째 IP |
|          |                             | Ex-Win  | DHCP           |

### 다) 스위치 설정 및 VLAN 구성

- 스위치의 호스트 이름 : CB-SW
- 모든 암호는 MD5 알고리즘으로 암호화되어 저장되어야 합니다.

- 콘솔접속 시 로컬계정(swAdmin) 으로 접속되도록 하며, 접속 시 바로 프리빌리지드 모드로 접속되어야 합니다. (콘솔 연결은 HOST-01 에서 사용할 수 있도록 한다.)
- 프리빌리지드 모드 접속 시 암호(cyberP@ss12#\$)를 사용합니다.
- 스위치에 SSHv2(도메인: kg.com)를 구성합니다. ssh 접속을 위해 sshUser 계정을 생성합니다.

| VLAN 구성 (CB-SW) |           |                  |
|-----------------|-----------|------------------|
| vlan ID         | vlan name | PORTS            |
| 10              | Web       | Fa0/1 ~ Fa0/2    |
| 20              | System    | Fa0/3 ~ Fa0/4    |
| 30              | Security  | Fa0/5 ~ Fa0/6    |
| 80              | DMZ       | Fa0/11 ~ Fa0/14  |
| 99(native)      |           | 사용하지 않는 모든 인터페이스 |
| 100             | External  | Fa0/15 ~ Fa0/18  |

| Trunk Port | 허용 vlan                   |
|------------|---------------------------|
| Fa0/19     | Internal 에서 사용하는 vlan만 허용 |
| Fa0/21     | DMZ 에서 사용하는 vlan만 허용      |
| Fa0/23     | External에서 사용하는 vlan만 허용  |

#### 라) UTM 및 통신 구성

- 호스트 이름 : CB-UTM
- 관리자 계정은 utmAdmin1 (암호 cyberP@ss12#\$)
- CB-L-01, CB-W-02의 네트워크에서만 관리자 페이지에 접속이 가능해야 합니다.
- ssh를 통한 접속 시 22202 로 접근 가능해야 한다.
- 영역 설정 : 내부망(eth1), DMZ(eth2), 외부망(eth3)
- 통신 가능한 방향 : 내부 -> 전체, DMZ-> 외부